Course Code: ITA1439 Course Name: Ethical Hacking Slot: A

CO1 – ASSIGNMENT_1

Nature of Assignment: Individual Duration: 1 Week Total Marks: 50

Student Name: CH. Ajith Kumar

Reg. No: 192324257

CO1: Apply the foundational concepts of ethical hacking, including the types of hackers, ethical principles, legal frameworks, and the role of responsible disclosure in cybersecurity.
Assignment Title: Design and Develop a Complete Ethical-Hacking Engagement Framework for a University's Authorized Security-Assessment Programme.

Scenario - University Authorized Security-Assessment Programme

A university is establishing an Authorized Security-Assessment Programme to test the security of its student portal, learning-management system, email service and campus network before a major upgrade. The programme must cover approximately 20 systems and 50 staff initially, but the framework is expected to remain usable as the programme grows to the whole university and begins to include external, third-party assessors.

The management has not yet fixed how ethical-hacking engagements will be governed. Testing may be requested by different departments, carried out by internal staff or external testers, and may touch systems that hold personal data. The team is concerned that an unstructured approach may lead to unauthorized access, legal exposure, damage to live systems, unclear scope or uncoordinated disclosure of discovered vulnerabilities.

You have been appointed as the Ethical-Hacking Governance Team. Your responsibility is not merely to describe hacking tools. You must investigate the requirements, design a complete engagement framework, construct reusable components and documents, integrate the different parts, validate the design through a walkthrough and defend the final framework using evidence.

The final framework must clearly distinguish between what is authorized, what is legal, and what is appropriate for the university. The team is expected to make governance decisions independently and justify why the framework is suitable for the given scenario. No live exploitation is performed; all work

stays at the design, documentation and isolated-lab level.

Design Challenge

Create and validate an integrated ethical-hacking engagement framework for the university programme. The framework must define how an engagement is authorized, how scope and rules of engagement are

set, how the relevant laws are respected, how different types of attackers are modelled, how discovered vulnerabilities are disclosed responsibly, and how an isolated lab is used where hands-on testing is required.

Your final design must be usable in practice and must demonstrate interaction among the selected components rather than treating each document or rule as an isolated example. Every major governance decision must be supported by evidence and a clear explanation of the trade offs involved.

TASK 1 – FORMULATE THE ENQUIRY AND FRAMEWORK BLUEPRINT

1.1 Governance requirements. The programme initially covers approximately 20 university systems and 50 staff members. The systems identified in the assignment are the student portal, learning-management system (LMS), university email service and campus network. The final inventory must identify each individual application, server, network range, cloud tenant, owner and third-party dependency before testing begins.

Stakeholders include the university management/sponsor, system and data owners, IT operations, information-security team, data-protection/privacy officer, legal office, internal testers, external assessors, service providers and affected users. Expected activities are request submission, risk assessment, written approval, scope definition, legal/privacy review, threat modelling, lab-based validation, evidence collection, remediation, retesting and coordinated disclosure.

Constraints are: no live exploitation in this assignment; no testing without written permission; no activity outside the approved target list and time window; protection of personal data; no service disruption; least-privilege access; secure evidence handling; and prompt escalation of unexpected impact.

1.2 Framework blueprint.

Stage	Responsible role	Input and control	Output / hand-off
1. Request	Department requester / system owner	Business purpose, systems, dates, risk and contacts	Unique engagement ID and request record
2. Authorization	Programme manager, system owner and delegated approver	Verify ownership, authority, signatures and third-party permission	Signed authorization; no approval means no testing
3. Scope and legal review	Security lead, privacy officer and legal office	Asset list, data categories, jurisdiction, techniques and exclusions	Approved scope, RoE and legal-control checklist
4. Threat model and plan	Lead tester	Actor profiles, attack paths, likelihood and impact	Test plan and risk-based test cases
5. Lab validation	Lab administrator and testers	Kali Linux plus deliberately vulnerable target VMs on host-only network	Contained test evidence and configuration record
6. Findings and remediation	Lead tester and system owner	Evidence, severity, business impact and remediation proposal	Structured finding report and tracked ticket
7. Disclosure and closure	Disclosure coordinator, legal/privacy and owner	Verified finding, risk, remediation status and deadlines	Coordinated notice, retest, closure and audit trail

The stages are linked by one engagement ID. Authorization unlocks the scope and RoE; the RoE constrains the test plan; legal/privacy review constrains data handling; the lab provides a safe place to validate techniques; findings feed remediation and disclosure; closure requires evidence that all findings are assigned and communicated.

1.3 Enquiry questions.

1. Who owns each target and who has delegated authority to approve testing?
2. Which exact IP addresses, domains, applications, accounts, dates and techniques are in scope?
3. Which Indian laws, contractual duties and third-party permissions apply to each system and data type?
4. How will personal data, credentials, logs and proof-of-concept evidence be minimised, protected and deleted?
5. How will a vulnerability be verified, prioritised, reported, remediated and disclosed?
6. How can the programme expand from 20 systems and 50 staff to university-wide and external-assessor use?

1.4 Acceptance criteria.

Criterion	**Acceptance test**
Authorization	Every engagement has a signed, current approval from the asset owner and delegated university approver.
Scope precision	Every target and permitted technique is listed; exclusions and testing windows are explicit.
Legal and privacy compliance	Legal/privacy review is completed and data collection is minimised and access-controlled.
Safety	Stop conditions, emergency contacts, rate limits and rollback/escalation procedures are documented.
Traceability	Requests, approvals, test actions, evidence, findings, decisions and closure are logged under one ID.
Disclosure	Each verified finding has an owner, severity, remediation due date and disclosure decision.
Scalability	Templates, roles and workflow support both internal and vetted external assessors.

Rationale: these criteria directly address the scenario's risks of unauthorized access, legal exposure, service damage, unclear scope and uncoordinated disclosure. An engagement cannot proceed merely because a test is technically possible; it must also be authorized, lawful and appropriate.

TASK 2 – DESIGN A HACKER THREAT MODEL AND CLASSIFICATION

2.1 Classification method. Classify an actor using four recorded dimensions: (a) authorization status—authorized, unauthorized or unclear; (b) intent—defensive, financial, disruptive, ideological, espionage or curiosity; (c) capability—low, moderate or advanced; and (d) access position—external, student/user, employee, administrator or supplier. The label describes observed behaviour and evidence, not an assumption about a person's identity.

Actor type	Typical motivation	Typical capability	Likely university targets
White-hat	Improve security with permission	Low to advanced; follows scope and reports findings	Approved portal, LMS, email and network assets
Black-hat	Financial gain, theft, disruption or extortion	Moderate to advanced; conceals activity and abuses access	Student records, accounts, payment systems, email
Grey-hat	Curiosity, reputation or public-interest claim without clear permission	Variable; may test without authorization	Public portal, exposed services and websites
Script kiddie	Curiosity, attention or disruption using ready-made tools	Usually low; relies on automated scripts	Public-facing login pages, Wi-Fi and exposed services
Hacktivist	Political or social cause, protest or publicity	Variable; defacement, leaks or denial-of-service attempts	University website, email, public announcements
Insider	Grievance, financial gain, negligence or misuse of legitimate access	Moderate to advanced; knows internal processes and systems	HR/student databases, shared drives, research data
State-sponsored actor	Espionage, strategic intelligence or influence	Often advanced, persistent and well-resourced	Research repositories, staff email, identity systems and network infrastructure

2.2 Consistent classification rules. Record the source of evidence, observed action, authorization status, intent indicators, capability indicators, access position, confidence level and date. Do not classify solely from an IP address or tool name. If evidence is incomplete, use “unconfirmed actor” and reassess when new facts are available.

2.3 Borderline example and alternatives. Consider a person who discovers an exposed LMS page and accesses a small amount of student information without permission, then emails the university saying the purpose was to help.

- Alternative A – White-hat: this could be argued if the person’s stated intention was defensive and they reported the issue.
- Alternative B – Grey-hat: this is more accurate because the person had no prior written authorization, even if the stated motive was helpful.

Final classification: Grey-hat, with moderate confidence. The decisive criterion is authorization, not claimed good intention. The university should preserve the report, avoid encouraging further access, request no additional data, and direct the person to the formal disclosure channel. The university should separately assess the conduct and the vulnerability without treating the report itself as permission.

TASK 3 – CREATE AN ETHICS AND CODE-OF-CONDUCT MODULE

3.1 Core ethical principles.

- Written authorization: begin only after approval by the asset owner and the university’s delegated authority.
- Agreed scope: test only listed assets, accounts, methods and time windows.
- Confidentiality: view only the minimum data necessary; never disclose student, staff or research information to unauthorized parties.
- Integrity: do not alter, delete, fabricate or conceal records; preserve evidence with timestamps and hashes where appropriate.
- Avoiding harm: use safe test methods, rate limits and stop conditions; do not interrupt teaching, examinations or essential services.
- Honest reporting: report successful and unsuccessful tests accurately, including limitations and uncertainty.
- Accountability: maintain logs, identify the tester responsible for each action and report incidents immediately.
- Least privilege and data minimisation: use test accounts and synthetic data wherever possible.

3.2 Preventive checks and decision rules. Before each test action, the tester checks: Is the target in the signed scope? Is the technique permitted? Is the test inside the approved window? Is the required account approved? Could the action expose personal data or affect availability? If any answer is “no” or “unknown”, pause and obtain written clarification. Emergency stop

triggers include unexpected production data access, service degradation, account lockout, third-party system discovery or a request to exceed scope.

3.3 Scenario test cases.

Scenario	Classification	Required response
Tester scans an approved lab target during the approved window and records results.	Acceptable	Continue within rate limits and retain logs.
Tester sees real student records while validating access control.	Borderline / stop condition	Stop at the minimum proof, do not copy records, notify lead and privacy officer, record minimal metadata.
Tester attempts password spraying against live staff accounts when not listed in RoE.	Unacceptable	Stop immediately; report deviation; investigate and revoke access if needed.
Tester finds a third-party payment endpoint linked from the portal but not listed in scope.	Unacceptable to test	Do not probe; request separate written authorization from the relevant owner/provider.
Tester reports a failed test as successful to improve the report.	Unacceptable	Correct the report, preserve audit evidence and escalate to programme manager.

3.4 Trust and professionalism. The module gives testers predictable boundaries and gives system owners evidence that testing is controlled. It protects users, limits collection of sensitive information, creates an auditable record and ensures that the university receives truthful findings. Ethical conduct is required even where a technical action might not clearly be prohibited by a particular statute.

TASK 4 – CONSTRUCT A LEGAL-COMPLIANCE MAPPING

4.1 Indian legal framework. The Information Technology Act, 2000 (IT Act) is relevant to unauthorized access, damage, identity misuse and disclosure of information. The Digital Personal Data Protection Act, 2023 (DPDP Act) and the Digital Personal Data Protection Rules, 2025 establish obligations for processing digital personal data, subject to their respective commencement provisions and applicability. The university must confirm the provisions in force on the date of each engagement and obtain legal advice for its institutional status and processing purposes.

Law / provision	Relevant conduct or obligation	Framework control
IT Act, 2000, s.43	Without permission, acts such as accessing, copying, extracting or damaging computer resources may attract civil liability/compensation.	Written authorization, exact scope, least privilege, safe test methods and audit logs.
IT Act, s.66	Acts described in s.43, when done dishonestly or fraudulently, may constitute a criminal offence.	Identity-verified testers, approval checks, monitoring and incident escalation.
IT Act, ss.66C–66D	Identity theft and cheating by personation using computer resources.	No impersonation or credential misuse outside explicitly approved test accounts; protect credentials.
IT Act, s.72	Breach of confidentiality and privacy by a person who obtains access under powers conferred by the Act.	Confidentiality undertakings, restricted evidence access and secure deletion.
IT Act, s.72A	Disclosure of personal information in breach of lawful contract, with the required wrongful intent/knowledge.	NDA, purpose limitation, no onward sharing and controlled reporting.
DPDP Act, 2023	Where applicable, governs processing of digital personal data and obligations of Data Fiduciaries and rights of Data Principals.	Data inventory, purpose limitation, minimisation, security safeguards, retention and breach escalation.
DPDP Rules, 2025	Provide implementation detail and phased commencement for specified rules.	Maintain a commencement checklist and implement applicable safeguards on their effective dates.
CFAA, 18 U.S.C. §1030	US federal law addressing specified unauthorized access, exceeding authorized access, damage and related computer offences.	Relevant only where jurisdictional facts create a US nexus; obtain counsel review and do not assume it governs a purely Indian engagement.

4.2 Offences, obligations and penalties. The following is a concise mapping, not a substitute for the current statutory text or legal advice.

Provision	Potential consequence / penalty (summary)	Practical implication
IT Act s.43	Compensation to the affected person for specified unauthorized acts; statutory compensation framework applies.	A tester must not assume that a harmless scan is lawful without permission.
IT Act s.66	Imprisonment up to 3 years, or fine up to ₹5 lakh, or both, for conduct meeting the section's requirements.	Dishonest or fraudulent unauthorized acts can escalate beyond civil liability.
IT Act s.66C	Imprisonment up to 3 years and fine up to ₹1 lakh.	Do not use another person's password, digital signature or unique identification feature.
IT Act s.66D	Imprisonment up to 3 years and fine up to ₹1 lakh.	Do not impersonate users or staff except within a specifically approved simulation.
IT Act s.72	Imprisonment up to 2 years, or fine up to ₹1 lakh, or both.	Keep confidential information restricted and do not disclose it improperly.
IT Act s.72A	Imprisonment up to 3 years, or fine up to ₹5 lakh, or both.	Contractors and testers must not disclose personal information obtained during services.
DPDP Act s.33	Penalty amounts depend on the contravention; the Act's Schedule provides monetary penalties, including up to ₹250 crore for failure to take reasonable security safeguards, where applicable.	Privacy/security controls and incident handling must be documented and implemented as applicable.
CFAA, 18 U.S.C. §1030	Penalties vary by subsection, intent, harm, prior convictions and circumstances; criminal fines and imprisonment may apply.	Only apply after jurisdictional analysis; the US statute is a comparison, not automatically applicable in India.

4.3 Personal-data decision. If testing touches student or staff personal data, the engagement must undergo a privacy review before approval. The preferred method is synthetic data or a designated test environment. If production access is unavoidable, the owner must approve the

purpose, minimum data fields, access controls, retention period, evidence redaction and deletion process. The university must determine whether it acts as a Data Fiduciary or another role under the DPDP Act and whether the relevant provisions have commenced. The IT Act and applicable contractual/confidentiality duties remain relevant independently. CFAA applies only if the facts establish a US jurisdictional connection.

4.4 Legal conclusion. Authorization is necessary but not a blanket exemption from privacy, confidentiality, contract or other legal obligations. The framework therefore requires both written permission and a legal/privacy assessment. Legal counsel must confirm current amendments, commencement dates, penalties and jurisdiction before a real engagement.

TASK 5 – CREATE A SCOPE AND RULES-OF-ENGAGEMENT DOCUMENT

5.1 Reusable Rules of Engagement (RoE) template.

Field	**Required content / default**
Engagement ID	Unique value, e.g., UNI-SEC-2026-001
Business purpose	Security assessment before the university system upgrade
Asset owner and approver	Named system owner plus delegated university approver
In-scope assets	Exact hostnames, IP addresses, applications, API endpoints, test accounts and network ranges; no wildcard unless explicitly approved
Out-of-scope assets	Third-party services, personal devices, payment gateways, production databases and any unlisted host
Testing window	Approved start/end date, time zone, maintenance window and blackout periods
Permitted techniques	Passive review, configuration review, controlled scanning and lab-based proof-of-concept validation as specifically approved
Prohibited techniques	Denial-of-service, destructive payloads, persistence, malware deployment, data exfiltration, social engineering or password attacks unless separately approved in writing
Safety limits	Rate limits, test-account limits, no changes to live records, stop conditions and rollback contact
Evidence handling	Minimum proof, redaction, encryption, access list, retention and deletion date

Escalation	Lead tester → security manager → system owner/incident response → privacy/legal as applicable
Third-party approval	Written permission from provider and university owner before any provider-controlled asset is tested

5.2 Authorization recording and verification. Store the signed authorization with the engagement record. Verify the signer's identity and role, asset ownership/delegation, exact target list, dates, techniques, third-party permissions and expiry. The programme manager checks that the document is signed and versioned, and records the approver, timestamp and document hash. Any change to scope, dates or methods requires a revised approval before the changed activity.

5.3 Boundary and naming rules. Use a unique engagement ID and an allow-list of exact targets. A target is out of scope if it is absent from the allow-list, belongs to a supplier without permission, resolves to a different owner, or is outside the approved time window. IP ownership or network proximity does not imply permission.

5.4 Pre-engagement checklist derived from the RoE.

- Request and business purpose recorded; engagement ID assigned.
- Asset owner and delegated approver identified and verified.
- Signed authorization is current and covers every target and method.
- Third-party approvals obtained where required.
- Scope allow-list and exclusions reviewed by tester and owner.
- Legal, privacy and data-classification review completed.
- Testing window, blackout periods and rate limits confirmed.
- Test accounts, lab targets, backups and rollback contacts ready.
- Emergency stop criteria and escalation contacts communicated.
- Evidence storage, access, retention and deletion arrangements confirmed.
- Team briefing completed; no testing begins until all mandatory checks pass.

TASK 6 – BUILD AN AUTHORIZATION AND DISCLOSURE LAYER

6.1 Authorization workflow.

7. Department submits a request containing purpose, assets, business owner, desired dates and known risks.
8. Programme coordinator assigns an engagement ID and checks completeness.
9. System owner verifies ownership and approves the exact assets and business impact.
10. Security lead reviews the method, tester competence, risk and RoE.
11. Privacy officer and legal office review personal-data, contractual and jurisdictional issues where relevant.
12. Delegated university authority signs the authorization; third-party owners separately sign where required.
13. Coordinator records the signed version, approvals, dates and hash, then issues a go/no-go decision.
14. Tester performs only approved activities; changes require a new approval.

15. Engagement is closed after findings, remediation ownership, evidence retention/deletion and lessons learned are recorded.

6.2 Coordinated disclosure process and timeline. A practical default target is: acknowledge receipt within 2 business days; triage and validate within 5 business days; assign severity and notify the owner immediately for critical findings; agree a remediation plan within 10 business days; target remediation within 30 calendar days for critical, 60 for high and 90 for medium findings, subject to risk and operational feasibility. Low findings may be scheduled in the next planned maintenance cycle. These are programme service targets, not statutory deadlines. If the changed requirement imposes a shorter timeline, the revised policy in Task 11 takes precedence.

Step	**Action and record**
Report	Reporter submits finding ID, affected asset, summary, impact, safe reproduction, evidence and contact details.
Acknowledge	Coordinator confirms receipt and provides a tracking reference.
Validate	Authorized team reproduces safely in the lab or approved target; no unnecessary data collection.
Classify	Security lead assigns severity, confidence, exploitability and affected data/service.
Notify	System owner, privacy/legal and incident response receive information on a need-to-know basis.
Remediate	Owner records fix, responsible person, target date and compensating controls.
Retest	Tester verifies the fix within scope and updates the finding.
Disclose and close	Coordinator approves closure or coordinated public notice after legal, privacy and owner review.

6.3 Comparison of disclosure approaches.

Approach	Meaning	Advantages	Risks / suitability
Coordinated disclosure	Reporter privately informs the owner and allows a reasonable fix period before public disclosure.	Supports remediation, reduces exposure and protects users.	Best default for university systems and personal data.
Full disclosure	Details are made public without waiting for the owner's remediation.	Can create pressure for action and inform defenders.	May expose users and increase exploitation risk; not the default for this programme.
Bug bounty	A structured programme invites reports under published scope and reward rules.	Scales reporting and provides clear researcher rules.	Requires triage capacity, legal terms, exclusions and budget; it is not a substitute for authorization.

6.4 Logging and release decision. Maintain an append-only register of request ID, approver, authorization version, scope, start/end time, tester, status changes, finding severity, owner, due date, disclosure decision and reason. Disclosure may proceed only when the finding is verified, the affected owner has been notified, sensitive details are reviewed/redacted, legal and privacy checks are complete, and the agreed remediation window has expired or an authorized exception is documented. Immediate public release is not automatic.

6.5 Interaction with RoE and legal controls. The authorization record must point to the exact RoE version. The finding report inherits the engagement ID and asset scope. Legal/privacy controls determine who may receive evidence and whether details must be redacted. A report about an out-of-scope asset is quarantined from testing and referred for separate authorization.

TASK 7 – DESIGN AN ISOLATED ETHICAL-HACKING LAB

7.1 Proposed lab topology. Use a host-only virtual network with the reserved range 192.168.56.0/24. Example addresses: Kali Linux tester VM 192.168.56.10/24; vulnerable target VM 192.168.56.20/24; optional second target VM 192.168.56.30/24. The host-only adapter connects the VMs to each other and the host but does not route test traffic to the university production network or the public Internet. Disable bridged adapters and disable shared folders/clipboard unless specifically needed and controlled.

7.2 Components and roles. The lab administrator creates and snapshots VMs, controls virtual networking and records configuration. The tester operates Kali Linux. Target VMs are deliberately vulnerable training systems owned or licensed for the exercise. The security lead approves test cases and reviews logs. No real student/staff data or production credentials are placed in the lab.

7.3 Configuration recording steps.

16. Record hypervisor name/version, host OS, VM names, image sources and image hashes.
17. Record each VM's CPU, memory, disk, snapshot ID and network adapter mode.
18. Record IP address, subnet mask, gateway (none for isolated host-only unless required), DNS and firewall rules.
19. Confirm no bridged adapter or unintended NAT route is active during the isolated test.
20. Take clean snapshots before testing and document the reset procedure.
21. Store screenshots and configuration exports with the engagement ID; redact host secrets.

7.4 Verification operations.

Operation A – Connectivity verification: from Kali, inspect the assigned interface and address, then ping 192.168.56.20. Confirm that the target is reachable only on the host-only segment. Record command output and timestamp. A failed ping does not by itself prove the host is down because ICMP may be blocked; verify using an approved service check.

Operation B – Isolation verification: inspect the VM adapter settings and routing table; confirm that the lab interface is host-only and that no default route or bridged interface provides a path to production. Attempt no scan of external or university networks. Record the adapter mode, routes and firewall configuration as evidence.

7.5 Host-only versus NAT.

Network mode	**Connectivity**	**Risk / limitation**	**Decision**
Host-only	VMs and host communicate on a private virtual segment; no direct Internet access by default.	Strong containment; updates and downloads need a controlled separate process.	Chosen for hands-on testing because isolation is the priority.
NAT	VMs can initiate outbound Internet connections through the host; unsolicited inbound connections are generally restricted.	Convenient for updates but creates an outbound path and increases misconfiguration risk.	Not used during testing; if updates are needed, use a separate controlled update phase and disconnect before testing.

7.6 Authorization and containment. The lab target list is included in the RoE and authorization. The tester uses only lab addresses and approved test accounts. Host-only networking, snapshots, synthetic data, disabled bridges and logged configuration reduce the chance of affecting real systems. Any test requiring production validation needs a separate approval and cannot be inferred from lab permission.

TASK 8 – DEVELOP A REUSABLE DOCUMENT LIBRARY

8.1 Reusable documents and fields.

Document	Required fields	Integration
A. Engagement Request and Authorization Form	Engagement ID; requester; purpose; asset owner; exact assets; dates; permitted methods; exclusions; data types; risk; approver names/signatures; version; expiry.	Creates the authorization record used by the RoE and workflow.
B. Rules of Engagement	Engagement ID; target allow-list; out-of-scope list; testing window; techniques; limits; stop conditions; escalation contacts; evidence handling; third-party approvals.	Constrains test execution and provides pre-engagement checklist fields.
C. Finding and Vulnerability Report	Finding ID; engagement ID; asset; title; description; severity; confidence; impact; safe reproduction; minimum evidence; data sensitivity; recommendation; owner; due date; status; disclosure decision.	Feeds remediation tracker, disclosure workflow and retest.
D. Closure and Retest Report	Finding ID; fix version; retest date; test performed; result; residual risk; evidence deletion date; owner acceptance; closure approval.	Closes findings and updates programme metrics.

8.2 Structured finding output. Each report should also be exportable as a consistent record, for example:

{"engagement_id":"UNI-SEC-2026-001","finding_id":"F-001","asset":"lms-test.example.edu","severity":"High","confidence":"High","status":"Open","owner":"LMS

System Owner","remediation_due":"2026-12-15","disclosure":"Coordinated","evidence_ref":"restricted://UNI-SEC-2026-001/F-001"}

This is an illustrative schema only. The evidence reference is an internal restricted identifier, not a public link. The finding ID and engagement ID link the report to the RoE, authorization, remediation ticket and disclosure register.

8.3 Input validation test entries.

Test input	Expected result
Valid: signed approval, exact in-scope asset, valid date window and named owner.	Accept; generate engagement ID and allow status to move to Approved.
Boundary: target list includes an approved subnet but one host is explicitly excluded.	Reject the excluded host; retain only explicitly approved targets.
Invalid: missing asset owner signature.	Reject; status remains Pending Authorization; testing blocked.
Invalid: testing end date earlier than start date or authorization expired.	Reject; require corrected dates or renewed authorization.
Invalid: finding severity is not one of Critical/High/Medium/Low/Informational.	Reject and request a valid controlled value.
Boundary: finding contains a student name or full record in evidence.	Quarantine; redact/minimise evidence and obtain privacy review before circulation.

8.4 Library governance. Store templates in a version-controlled, access-restricted repository. Assign a document owner, version number, approval date and review date. External assessors receive only the current approved templates and engagement-specific documents. Old versions remain archived for audit but cannot be used to authorize new work.

TASK 9 – INTEGRATE, TEST AND REFINE THE FRAMEWORK

9.1 Integrated walkthrough. Example engagement UNI-SEC-2026-001: the LMS owner requests an assessment before an upgrade. The coordinator records the request; the owner and delegated authority sign the target list; security, legal and privacy teams review the plan; the RoE restricts testing to the LMS test environment and approved hours; the lead tester models likely threats; approved tests are performed against the isolated lab target; a high-severity access-control weakness is documented with minimum evidence; the owner receives a coordinated report and remediation deadline; the fix is retested; the finding is closed and evidence is retained/deleted under policy.

9.2 Systematic test cases.

Test case	Input / event	Expected framework response
TC-01 Missing authorization	Request is submitted but no signed owner approval exists.	Block all testing; status Pending Authorization; log missing approval.
TC-02 Out-of-scope request	Tester is asked to scan an unlisted supplier host.	Refuse and stop; request separate supplier and university authorization.
TC-03 Legal/privacy conflict	Proposed test would copy identifiable student records without a documented need.	Pause; privacy/legal review; substitute synthetic data or minimise proof.
TC-04 Delayed disclosure	Owner misses agreed remediation date.	Escalate to security governance; review risk and compensating controls; revise disclosure decision with documented approval.
TC-05 Expired authorization	Testing is attempted after the approved end date.	Block activity until a new authorization is approved.
TC-06 Critical service impact	Unexpected service degradation occurs during an approved test.	Stop test, notify incident response and owner, preserve logs and support recovery.

9.3 Problems found in the walkthrough and refinements.

Problem observed	Refinement
An asset hostname resolves to a third-party service.	Add ownership verification and third-party permission check before allow-list approval.
Evidence may contain personal data.	Require data-minimisation, redaction and privacy approval before evidence distribution.
Approval status is unclear across teams.	Use one engagement ID, a central status register and named workflow owner.

Disclosure deadline may be missed.	Add automated due-date escalation and a documented exception process.
Tester could use an outdated RoE.	Version-lock the RoE to the authorization and show the approved version in the test pack.

9.4 Final integrated control. A test is permitted only when authorization is valid, the target is in scope, the RoE permits the technique, legal/privacy checks are complete and the lab or approved environment is ready. A finding cannot be closed until its owner, remediation, retest result and disclosure status are recorded. These dependencies make the framework reproducible and auditable.

TASK 10 – CREATE A SCALABILITY AND GOVERNANCE EVALUATION

10.1 Evaluation scenarios. The figures below are planning assumptions for comparing governance workload, not measured results from a live university system. They can be replaced with actual timings during a controlled pilot.

Measure	**Small programme – one department**	**Large programme – whole university**
Systems	5 systems	20 systems initially, expandable to all university systems
Staff / testers	10 staff; 2 internal testers	50 staff initially; 6 internal testers plus 4 vetted external assessors
Requests per cycle	2 engagements	10 engagements
Approval turnaround target	3 business days	5 business days with parallel owner/privacy/legal reviews
Scope coverage target	100% of approved assets	100% of approved assets with owner and dependency mapping
Workflow steps	8 standard steps	8 standard steps plus supplier onboarding and additional privacy checks
Evidence handling	Central restricted folder	Role-based repository, retention schedule and external-assessor segregation

10.2 Process evaluation using illustrative pilot estimates.

Process	Small: estimated effort	Large: estimated effort	Interpretation
Authorization	1–2 business days; 1 owner approval	3–5 business days; multiple owners and legal/privacy review	Large programme needs delegated approvers and parallel review.
Scope verification	1 checklist; 5 systems	Asset-owner confirmation for 20+ systems and dependencies	Automated asset inventory and allow-list validation reduce omissions.
Finding disclosure	1 coordinator and owner	Central coordinator plus system owner, privacy/legal and external reporter	Severity-based routing and due-date escalation are required.

10.3 Structured visualization of process growth.

Process	Small programme	Large programme
Approval parties	2–3	4–6 or more
Systems requiring scope validation	5	20 initially; university-wide later
Assessor categories	Internal	Internal and external
Governance model	Central coordinator	Central policy with delegated system owners

A simple comparison is shown below: scope validation grows from 5 systems in the small scenario to at least 20 systems in the initial large scenario (4 times the asset count). The programme should therefore scale through reusable templates, central registers, asset-owner delegation and parallel reviews rather than relying on one coordinator to manually approve every detail.

10.4 Governance refinements based on the evaluation. Introduce risk-tiered approvals: low-risk lab-only assessments use a standard approval path; assessments involving production services, personal data or third-party systems require additional reviews. Create an approved assessor register, standard onboarding and confidentiality terms. Use a central asset inventory and engagement dashboard to monitor approval turnaround, percentage of assets with verified

owners, overdue findings and disclosure deadlines. The measures are proposed evaluation targets and must be validated with actual pilot data.

TASK 11 – DEFEND THE FRAMEWORK UNDER A CHANGED REQUIREMENT

11.1 Changed requirement response. The university now performs continuous and third-party assessments, applies stricter data-protection rules and requires a shorter disclosure timeline. The framework must retain its core authorization, scope, ethics, legal mapping, lab, document library and audit trail, while adding continuous-assessment controls and stronger external-assessor governance.

Component	Decision	Revised design
Authorization workflow	Modify	Time-bound standing authorization for defined recurring tests, with periodic owner reconfirmation and immediate revocation when assets or risk change.
Scope and RoE	Modify	Versioned machine-readable allow-lists, explicit exclusions, test windows, rate limits and change approval for every new asset.
Legal/privacy mapping	Strengthen	Privacy impact screening before each new data use; synthetic data by default; role-based access, encryption, retention limits and breach escalation.
Threat model and ethics	Retain and update	Add supplier/assessor risk, insider misuse, credential handling and continuous monitoring scenarios.
Isolated lab	Retain	Use for exploit validation and training; production testing remains separately authorized and risk-controlled.

Disclosure process	Redesign	Shorter internal targets: acknowledge within 1 business day, triage within 2 business days, critical owner notification immediately, remediation plan within 3 business days; agree a risk-based fix deadline and escalate overdue items.
Document library	Modify	Add third-party due diligence, data-processing terms, assessor access expiry, recurring-test approval and evidence-deletion attestations.
Governance metrics	Expand	Dashboard for continuous test runs, authorization expiry, scope drift, critical findings, privacy incidents and overdue remediation.

11.2 New component – Continuous and Third-Party Assessment Control.

22. Onboard each external assessor through identity verification, competence review, confidentiality agreement, conflict-of-interest declaration and approved access expiry.
23. Create a separate engagement ID and restricted access profile for each assessor and each assessment period.
24. Permit recurring scans only against an approved, versioned asset allow-list; any new asset or technique requires owner approval.
25. Use rate limits, maintenance windows, health monitoring and automatic stop conditions for service degradation.
26. Keep personal data out of test evidence by default; use synthetic records and redact any unavoidable identifiers.
27. Review assessor access and scope at each cycle; revoke access at expiry or on contract termination.
28. Route findings through the central triage queue with severity-based notification and shorter internal service targets.
29. Require remediation owner, target date, retest result and evidence-deletion confirmation before closure.

11.3 Integration. The new control consumes the signed authorization and RoE, validates each scheduled test against the allow-list, checks the assessor’s active status, and sends results to the finding library. The disclosure layer uses severity and data sensitivity to route

notifications. The legal/privacy layer controls evidence access and retention. The governance dashboard measures expiry, scope drift, response times and remediation.

11.4 Evidence-based defence. The walkthrough demonstrated why signed authorization, explicit scope and a stop rule are essential. The legal mapping showed that permission alone does not remove privacy and confidentiality duties. The lab design provides a contained place for hands-on validation. The scalability evaluation showed that multiple owners and external assessors require delegated approvals, standard templates and a central register. The coordinated-disclosure process supports remediation before public release. Together, these controls make the revised framework suitable for continuous and third-party use.

11.5 Remaining trade-offs and future improvements.

- Speed versus assurance: shorter disclosure and approval timelines improve responsiveness but can overload system owners and legal/privacy reviewers. Improve this through risk-based routing, delegated approvers and pre-approved templates.
- Continuous testing versus availability: frequent scans can affect live services. Improve this through rate limits, monitoring, maintenance windows, canary testing and automatic stop controls.
- Central governance versus local ownership: central policy gives consistency, while departments understand their systems best. Improve this through central minimum standards with named local asset owners.
- External assessor capability versus data exposure: third parties add expertise but increase access and confidentiality risks. Improve through due diligence, least privilege, segregated evidence, access expiry and audit rights.

Final conclusion: The proposed framework establishes a controlled lifecycle from request to authorization, scope, legal review, threat modelling, safe testing, finding validation, coordinated disclosure, remediation and closure. It distinguishes authorization, legality and appropriateness: written permission defines what the university allows; applicable law defines legal duties and prohibitions; ethical and institutional controls determine what is responsible and suitable. The framework is reusable, auditable and extensible for the university's initial 20 systems and 50 staff and for future university-wide and third-party assessments.

REFERENCES AND LEGAL NOTES

1. Government of India, Information Technology Act, 2000, India Code: https://www.indiacode.nic.in/indiacode/handle/123456789/1999?locale=en

2. Ministry of Electronics and Information Technology, Digital Personal Data Protection Rules, 2025, Gazette notification dated 13 November 2025: https://www.meity.gov.in/static/uploads/2025/11/53450e6e5dc0bfa85ebd78686cadad39.pdf

3. Government of India, Press Information Bureau, "Government notifies DPDP Rules to empower citizens and protect privacy", 14 November 2025: https://www.pib.gov.in/PressReleasePage.aspx?PRID=2190014&lang=2&reg=3

4. United States Code, 18 U.S.C. §1030, Fraud and related activity in connection with computers: https://uscode.house.gov/usc/view.xhtml?req=granuleid:USC-prelim-title18-section1030

Legal note: This assignment is an academic governance design, not legal advice. Statutory provisions, amendments, commencement dates, institutional roles and penalties must be checked by qualified counsel before a real engagement. The DPDP Rules, 2025 have phased commencement; the relevant provisions should be checked against the date of the proposed processing or assessment.

MARK DISTRIBUTION

Task	Marks
TASK 1 – Formulate	4
TASK 2 – Design	4
TASK 3 – Create	4
TASK 4 – Construct	4
TASK 5 – Create	4
TASK 6 – Build	5
TASK 7 – Design	5
TASK 8 – Develop	5

TASK 9 – Integrate	5
TASK 10 – Create	5
TASK 11 – Defend	5
TOTAL	**50**